

소개

중고거래 플랫폼

개발과정은 docs/plan.md에 존재합니다.

https://github.com/developer-commit/tiny_second_hand_shopping_platfrom

요구사항 구현 정도

사람들이 플랫폼에 가입할수 있어야 함 - 구현완료 상품을 올리고 볼수 있어야 함. - 구현완료 플랫폼 사용자들이끼리 소통이 가능해야함. - 부분적 구현(단체 채팅 제외) 악성 유저나 상품을 차단해야 함 - 더미 코드(미 구현) 유저간 송금이 가능해야함. - 이더리움을 이용해 구현하려 했으나 버그 해결 못함(구현 중 실패) 상품의 검색할 수 있어야 함 - 구현 완료 관리자가 플랫폼의 모든 요소를 관리할 수 있어야 함. - 관리자 승격만 존재, 더미코드 (미구현)

보안 체크리스트

섹션	체크리스트 항목	상태	위험도	증거 파일	OWASP/CWE 매핑	신뢰도
1	1.1 서버 측 입력 유효성 검사	PASS	정보성	user_dto.rs (SignUpReq)	ASVS V5	높음
1	1.2 CSRF 보호	NOT APPLICABLE	정보성	middleware/auth.rs	ASVS V4.2.2	높음
1	1.3 비밀번호 보안	PASS	정보성	auth_service.rs (sign_up)	ASVS V2.1, CWE-256	높음
1	1.4 세션 쿠키 보안	NOT APPLICABLE	정보성	middleware/auth.rs	ASVS V3.4	높음
1	1.5 세션 만료 및 재인증	PARTIAL	중간	auth_service.rs (login)	ASVS V3.1, CWE-613	높음
1	1.6 로그인 실패 보호	PARTIAL	낮음	auth_handler.rs (login)	ASVS V2.2.1, CWE-307	높음
1	1.7 에러 처리	PASS	정보성	utils/error.rs	ASVS V7, CWE-209	높음

섹션	체크리스트 항목	상태	위험도	증거 파일	OWASP/CWE 매핑	신뢰도
2	2.1 폼 입력 유효성 검사	PASS	정보성	product_dto.rs (CreateItemReq)	ASVS V5.1	높음
2	2.2 XSS 보호	PASS	정보성	product_handler.rs	ASVS V5.3, CWE-79	높음
2	2.3 인증된 제품 관리	PASS	정보성	router.rs	ASVS V4.1	높음
2	2.4 소유권 검증	PASS	정보성	product_service.rs (update_product)	ASVS V4.1, CWE-284	높음
2	2.5 데이터 무결성	PASS	정보성	product_service.rs (create_product)	ASVS V5.1.4	높음
3	3.1 메시지 내용 검증	PASS	정보성	chat_dto.rs (SendMessageReq)	ASVS V5.1.1	높음
3	3.2 WebSocket 인증	PASS	정보성	chat_handler.rs (websocket_handler)	OWASP WS Sec	높음
3	3.3 메시지 검증 및 인가	FAIL	심각	chat_service.rs (get_history)	ASVS V4.1.1, CWE-639	높음
3	3.4 속도 제한 및 남용 방지	FAIL	높음	router.rs, chat_handler.rs	ASVS V11.1, CWE-770	높음
3	3.5 전송 암호화	UNKNOWN	정보성	router.rs	ASVS V9, CWE-319	높음
4	4.1 신고 입력 검증	PASS	정보성	report_dto.rs (SubmitReportReq)	ASVS V5.1	높음
4	4.2 인증된 접근	PASS	정보성	report_handler.rs	ASVS V2.1	높음
4	4.3 데이터 무결성 및 감사 로깅	PARTIAL	낮음	report_service.rs	ASVS V7.1.1, CWE-778	높음

섹션	체크리스트 항목	상태	위험도	증거 파일	OWASP/CWE 매핑	신뢰도
4	4.4 신고 남용 방지	FAIL	높음	report_service.rs (apply_auto...)	ASVS V11.1, CWE-799	높음

실행방법

```
docker compose -f docker/docker-compose.yml build app
docker compose -f docker/docker-compose.yml up -d

#상태확인
docker compose -f docker/docker-compose.yml ps
docker compose -f docker/docker-compose.yml logs -f app

#종료
docker compose -f docker/docker-compose.yml down -v
```

<http://localhost:8080/> 을 통해 접속 가능합니다. 이후 `python_test/fast_signup.py`를 사용하면 빠르게 회원가입, 세팅이 가능합니다.

송금 환경 테스트용 클라이언트

https://github.com/developer-commit/ethereum_tui_simulator

추가사항

인증번호가 고정적으로 생성되고(000000), 이메일이 발송되지 않습니다.